

FIAP - FACULDADE DE INFORMÁTICA E ADMINISTRAÇÃO PAULISTA
DEFESA CIBERNÉTICA



VINICIUS SERAFIM DE OLIVEIRA - RM559144

GLOBAL SOLUTION 2024-1
CYBER WARGAMES

SÃO PAULO
2024

LISTA DE ILUSTRAÇÕES

FIGURA 1 – <i>PARAMETER</i>	9
FIGURA 2 – <i>HTTP STATUS</i>	9
FIGURA 3 – <i>COUNT</i>	10
FIGURA 4 – <i>FILTER</i>	10
FIGURA 5 – <i>RANKING</i>	11
FIGURA 6 – TOP IP	11
FIGURA 7 – TRAFFIC	12
FIGURA 8 – CAPTURED	12
FIGURA 9 – HALK	13
FIGURA 10 – ALIEN	13
FIGURA 11 – WIFI	14
FIGURA 12 – CHAT	14
FIGURA 13 – RIPPER	14
FIGURA 14 – EXTRACTED	15
FIGURA 15 – DECRYPT	16
FIGURA 16 – PING OF DEATH	16
FIGURA 17 – HIDDEN	17

SUMÁRIO

1. INTRODUÇÃO	3
2. WRITEUP CTF'S	4
2.1. CTF (URL SUSPEITA)	4
2.2. CTF (SOMANDO).....	4
2.3. CTF (TOP USER-AGENT)	4
2.4. CTF (TOP IP).....	5
2.5. CTF (O SEXTO HOST)	5
2.6. CTF (USUÁRIO DESTRUIDOR)	5
2.7. CTF (VAZAMENTO).....	5
2.8. CTF (CRIPTOGRAFIA ALIENÍGENA).....	6
2.9. CTF (OBSOLETO)	6
2.10. CTF (CONVERSA SUSPEITA)	6
2.11. CTF (SOMENTE NÚMEROS).....	6
2.12. CTF (BLUE OF DEATH).....	7
2.13. CTF (TEMPO E ESPAÇO)	7
2.14. CTF (CABO PERDIDO).....	7
2.15. CTF (COMANDO BÁSICO).....	8
3. EXEMPLOS DE ILUSTRAÇÕES.....	9
4. CONSIDERAÇÕES FINAIS	18
5. REFERÊNCIAS.....	19

1. INTRODUÇÃO

Este documento tem como objetivo apresentar, com a presença de imagens, e de descrições detalhadas, como foram solucionados os CTFs (*Capture the flag*) da prova *Global Solution* do 1º semestre de 2024.

Todas as soluções são apresentadas com o título do CTF juntamente com uma descrição e um conjunto de imagens para exemplificar as etapas de resolução do desafio proposto. Acerca das imagens, elas possuem em seu canto superior esquerdo o meu prontuário juntamente com o nome da minha máquina, intitulada de “*bellatrix*”, colocado através da ferramenta *waybar* (barra de tarefas altamente customizável), já no canto superior direito temos a presença da data e hora da captura da tela.

Conforme Bruce Schneier, "A segurança da informação não é um problema, é uma oportunidade." Este relatório demonstra como os CTFs podem ser aproveitados como oportunidades para aprimorar as habilidades em defesa cibernética.

2.WRITEUP CTF'S

2.1. CTF (URL SUSPEITA)

O arquivo de *log*, disponibilizado junto com o CTF, continha dados relevantes para a investigação. Ao abri-lo, percebi que as informações estavam separadas por espaços, facilitando a análise. Portanto, utilizei a funcionalidade "Texto para coluna" do LibreOffice para organizar os dados em colunas distintas, otimizando a visualização.

Ao analisar os *endpoints* das requisições, identifiquei um parâmetro crucial chamado "*flag*" em uma das requisições. Este parâmetro continha um valor em Hexadecimal, empregando o decodificador online *DenCoder*, decodifiquei o valor do parâmetro "*flag*", desta forma encontra-se a chave do desafio.

Através da análise meticulosa do arquivo de log e da utilização de ferramentas adequadas, como o *LibreOffice* e o *DenCoder*, foi possível desvendar os segredos codificados e avançar na resolução do CTF.

2.2. CTF (SOMANDO)

Da mesma forma que o CTF anterior, ao abrir o arquivo, me deparo com um Log (o mesmo do CTF anterior. Entretanto, desta vez prefiro utilizar o *AWK* para analisar. A coluna de índice 9 informa o status da resposta para aquela requisição, então posso perceber que todas as requisições são status 200 ou 404, portanto não há necessidade de criar um filtro, basta ver o número de requisições através do comando "wc -l", o qual é 71.

2.3. CTF (TOP USER-AGENT)

O objetivo deste CTF é identificar o sexto *user-agent* mais utilizado em um arquivo *PCAP*, que representa um registro de atividades na rede. Começo com a filtragem dos pacotes relevantes, para isso, preciso aplicar o filtro "*https.user-agent*". Então, exporto os dados para um arquivo CSV. No LibreOffice, filtro o *user-agent* (campo identifica um programa) único.

Para finalizar, utilizo a função "*CONTIF()*", essa função contará o número de vezes que cada *user-agent* aparece na tabela. Por fim, ordenaremos a tabela de forma decrescente em relação à contagem de aparições, a nossa flag será o sexto elemento da tabela.

2.4. CTF (TOP IP)

Nesse CTF precisamos colocar alguns filtros no *Wireshark* (Programa de computador que intercepta pacotes de rede) como o enunciado pede, após isso, entramos no menu "conversation" e ordenamos por quantidade de pacotes, e vejo que só 2 endereços IPs atenderam aos filtros, portanto eu acho a flag colocando o último endereço IP.

2.5. CTF (O SEXTO HOST)

Para resolver esse CTF, antes da alteração do enunciado, foi preciso habilitar a resolução de nomes no *Wireshark*, e então, entramos no menu "conversation" e ordenamos pela quantidade de pacotes transferidos.

2.6. CTF (USUÁRIO DESTRUIDOR)

Para encontrar o que estamos procurando, primeiro eu utilizo o filtro do Visualizador de eventos, mais precisamente o filtro "4720", que se refere a criação de usuários. Assim, chegamos a flag, pois logo podemos encontrar o usuário responsável pela bagunça.

2.7. CTF (VAZAMENTO)

Ao ordenar os pacotes por protocolo, pude notar que um deles continha um valor codificado em Base64. Desta forma, chega-se a flag decodificando o valor encontrado.

2.8. CTF (CRIPTOGRAFIA ALIENÍGENA)

O arquivo disponibilizado no CTF contém vários “0” e “1”, como estão em uma ordem fixa, descarto a possibilidade de ser binário, então eu apenas os removo. Após isso, chego a uma flag, porém ao analisar, vejo que é um valor criptografado, então tento um decodificador online, mas nenhum resultado é valor verdadeiro, então pode ser uma cifra de deslocamento, como a Cifra de César, através dela eu encontro a minha resposta, deslocando 3 posições para trás.

2.9. CTF (OBSOLETO)

Ao analisar o arquivo, vejo que se trata de pacotes transferidos via “Wi-Fi”, então começo a procurar por SSID que possa ser relevante, para isso eu coloco a SSID como uma coluna. Então e acho a seguinte rede “*encryptCTF*”. Após isso busco por ferramentas para analisar os pacotes WEP, então eu instalo o *aircracke-ng* (programa para quebra de pacotes WIFI)

Então, bastou executar o *aircracke* pelo arquivo e chegamos ao valor da flag.

2.10. CTF (CONVERSA SUSPEITA)

Ao abrir o arquivo no *Wireshark* já procuro pelos pacotes TCP, ao analisar os pacotes noto que os *payloads* parecem legíveis, e realmente são, um dos *hosts* informa um valor codificado em Base64. Ao decodificar esse valor achamos a flag do desafio.

2.11. CTF (SOMENTE NÚMEROS)

Junto desse CTF foi deixado um arquivo em PDF, entretanto com uma senha. Nossa missão era quebrar essa senha, para isso utilizei uma ferramenta chamada “*Pdfrip*”, ela foi capaz de quebrar a senha em poucos segundos, já que o enunciado dava a dica que a senha possuía apenas números e oito dígitos. Com base nas dicas do enunciado executei o *Pdfrip* de forma que testasse apenas senhas que fossem uteis para esse caso, isso é, uma faixa de 1000000 a 99999999, e assim descobri a senha em menos de 10 segundos.

2.12. CTF (BLUE OF DEATH)

Esse desafio nos cedeu um arquivo com a extensão “doc”, entretanto não era a sua real extensão, sua real extensão era na verdade “mdmp” um *dump* (despejo) de memória, por ele podemos acessar valores armazenados na memória de uma máquina. Após horas analisando o arquivo pelo *Windbg* (depurador de despejos de memória), procurei outras ferramentas para analisar o arquivo, após buscar por “*credentials dump tools*” achei uma ferramenta chamada *mimikatz* (conjunto de ferramenta para extração em memória), capaz de explorar a segurança do *Windows* e extrair em texto puro usuário e senha.

Depois de entender como ela funciona, basta dois comandos e a senha é completamente exposta, basta apontar o *mimikatz* para o nosso arquivo de despejo.

2.13. CTF (TEMPO E ESPAÇO)

Nesse CTF, bastou fazer uma pesquisa rápida para encontrar um mesmo desafio solucionado por um estrangeiro, após copiar o código, basta fazer uma pequena modificação e executar o *script*. As modificações que fiz foram apenas na formatação da flag, pois utilizamos o padrão “FIAP{”.

2.14. CTF (CABO PERDIDO)

Após dois dias finalmente conseguimos solucionar o “CABO PERDIDO”, um enigma dividido em três arquivos de registros de pacotes. Após tentar analisar pelo *Wireshark*, busco por ferramentas online e encontro o *Dynamite* (Site para análise se pacotes de rede), mas ao tentar fazer *upload* do arquivo a plataforma exibe um erro dizendo aquele um arquivo com aquele *hash* (valor garantir integridade de um arquivo) já existe no banco de dados deles, então eu procuro por esse arquivo na *internet*, e novamente um usuário, intitulado *XIL*, já publicou a resolução.

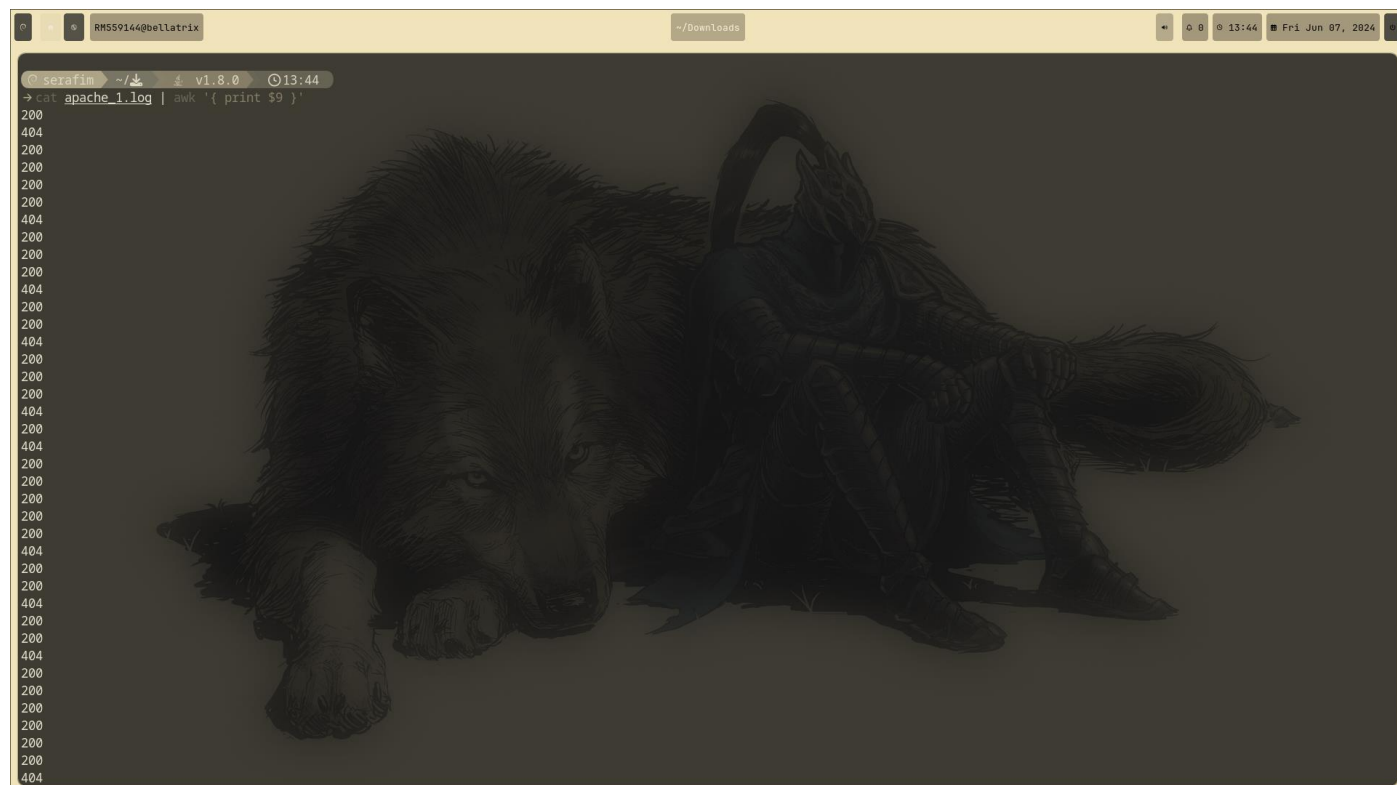
O *writeup* (redação) do usuário já deixou a resposta do desafio, então bastou montar na nossa flag, visto que consistia no mesmo arquivo, portanto a flag seria a mesma, o que poupou tempo e me garantiu o *firstblood* (dentro da plataforma, significa ser o primeiro a eliminar o desafio).

2.15. CTF (COMANDO BÁSICO)

Como usuário *linux* (nucleo de gerenciamento de recursos de um computador), tive que estudar um pouco sobre os comandos “dir” e o “attrib”, mas no fundo foi uma pesquisa rápida e já encontrei os parâmetros necessários para concluir o desafio.

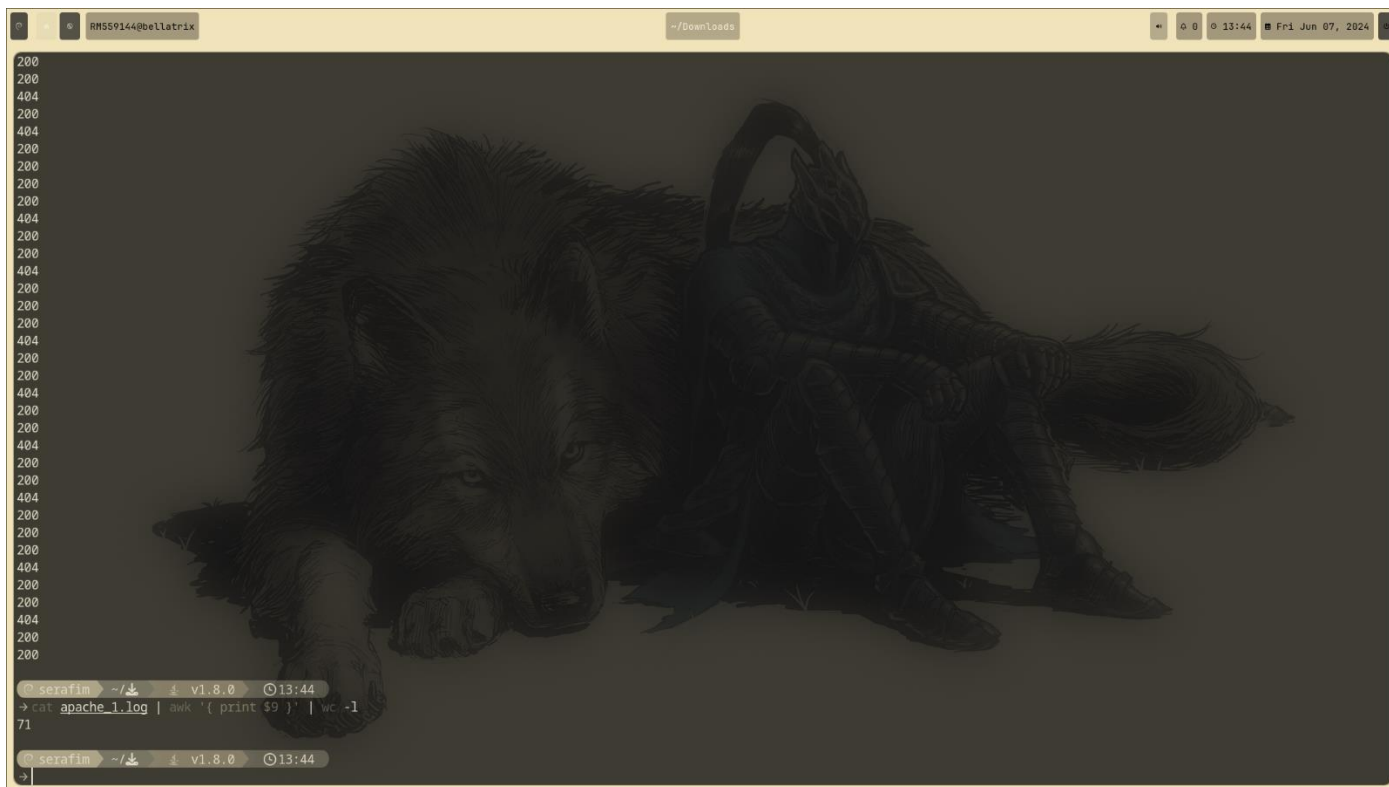
```
serafim ~/Downloads/CTFs 20:38  
→ cat apache_1.log | awk '{ print $7 }' | tail -n 30  
/about.php  
/login.php  
/index.php  
/contact.php  
/about.php  
/login.php  
/index.php  
/contact.php  
/about.php  
/login.php  
/index.php  
/contact.php  
/about.php  
/login.php  
/index.php  
/contact.php  
/about.php  
/login.php  
/index.php  
/contact.php  
/about.php  
/login.php  
/index.php?flag=464941507B6C696E75785F666696C7465727D  
/contact.php  
/about.php  
/login.php  
/index.php  
/contact.php  
/about.php  
/login.php  
/index.php  
/contact.php  
/about.php  
/login.php  
  
serafim ~/Downloads/CTFs 20:38  
→ |
```

FIGURA 2 – HTTP STATUS



(Resolução do CTF SOMANDO)

FIGURA 3 – COUNT



(Resolução do CTF SOMANDO)

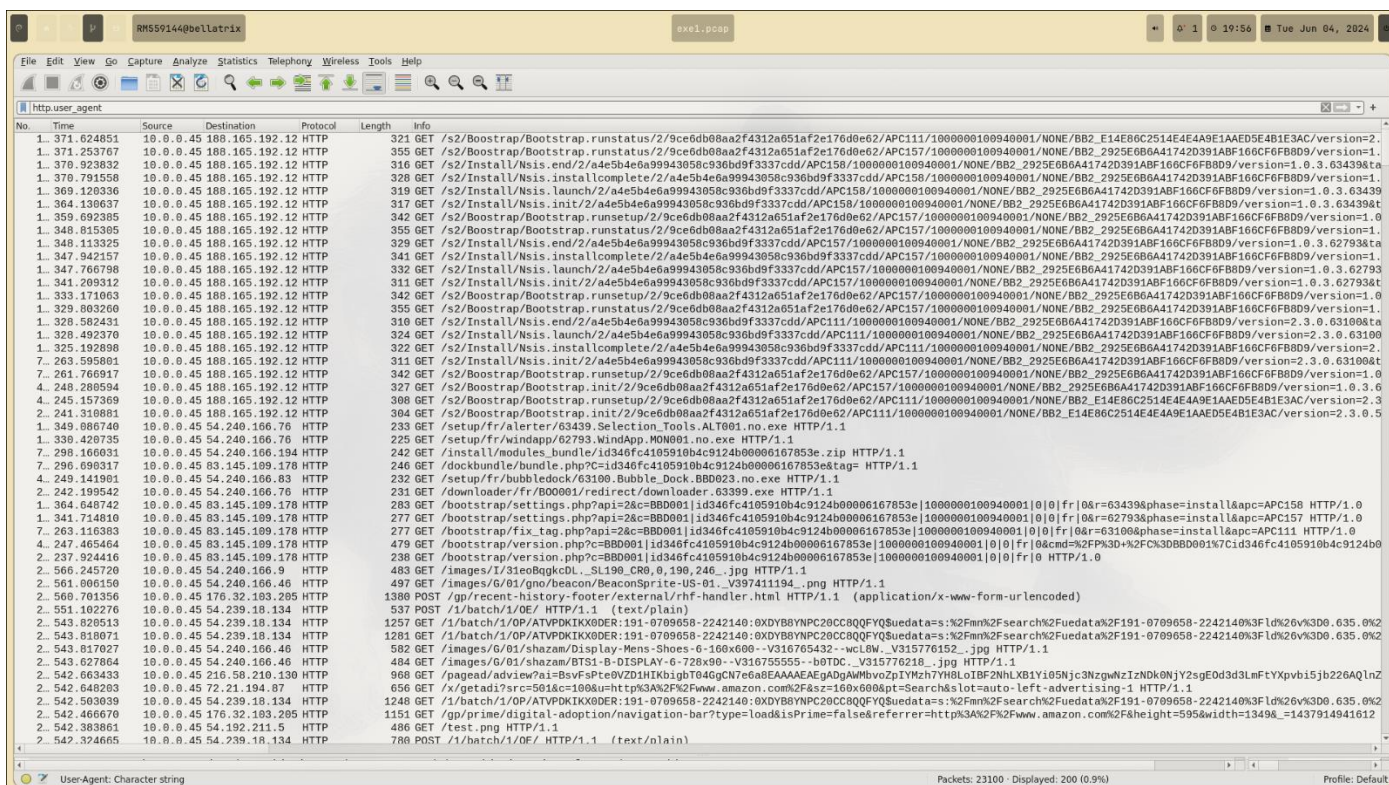
FIGURA 4 – *FILTER*(Resolução do CTF *TOP USER-AGENT*)

FIGURA 5 – RANKING

User-Agent	Cont
Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0	104
Mozilla/4.0 (compatible; MSNbot; 1.0)	30
Mozilla/4.0 (compatible; MSNbot; 1.0)	28
urlRequest	22
NSIS_Inetc (Mozilla)	6
NSISDL/1.2 (Mozilla)	5
Mozilla/4.0 (compatible; MSNbot; 1.0)	3
Microsoft-CryptoAPI/6.1	2

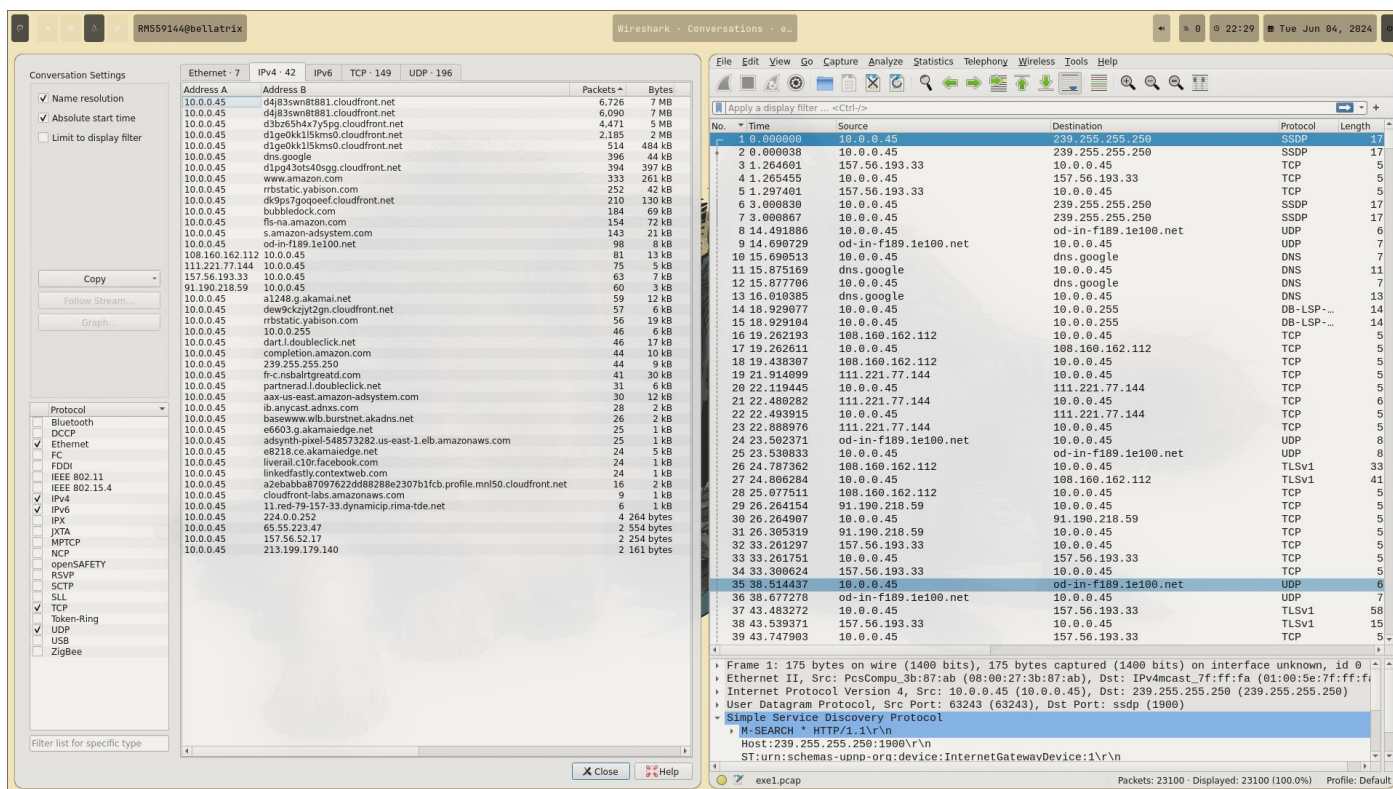
(Resolução CTF TOP USER-AGENT)

FIGURA 6 – TOP IP

No.	Time	Source	Destination	Protocol	Length	Info
19	21.22.4802	111.221.77.144	10.0.0.45	TCP	64	9b71e64eb38aa66eb2a8
21	22.8889	111.221.77.144	10.0.0.45	TCP	54	
23	26.2641	91.190.218.59	10.0.0.45	TCP	54	
31	26.3953	91.190.218.59	10.0.0.45	TCP	54	
54	54.2788	111.221.77.144	10.0.0.45	TCP	54	
56	54.5747	111.221.77.144	10.0.0.45	TCP	54	
65	57.3547	91.190.218.59	10.0.0.45	TCP	59	26195a04e9
85	86.2692	111.221.77.144	10.0.0.45	TCP	54	
87	86.5810	111.221.77.144	10.0.0.45	TCP	54	
89	89.2696	91.190.218.59	10.0.0.45	TCP	54	
91	89.2997	91.190.218.59	10.0.0.45	TCP	54	
109	110.859	111.221.77.144	10.0.0.45	TCP	54	
110	110.868	111.221.77.144	10.0.0.45	TCP	57	599a17
112	111.465	111.221.77.144	10.0.0.45	TCP	111	44831dc66a289b671fa261e4e6243e81d689
119	117.685	111.221.77.144	10.0.0.45	TCP	54	
121	118.086	111.221.77.144	10.0.0.45	TCP	54	
122	118.007	111.221.77.144	10.0.0.45	TCP	58	582a7391
124	119.214	91.190.218.59	10.0.0.45	TCP	54	
126	119.256	91.190.218.59	10.0.0.45	TCP	54	
146	148.233	111.221.77.144	10.0.0.45	TCP	54	
148	148.538	111.221.77.144	10.0.0.45	TCP	54	
149	149.214	91.190.218.59	10.0.0.45	TCP	54	
151	149.255	91.190.218.59	10.0.0.45	TCP	54	
164	189.269	111.221.77.144	10.0.0.45	TCP	54	
168	189.568	111.221.77.144	10.0.0.45	TCP	54	
169	181.263	91.190.218.59	10.0.0.45	TCP	54	
171	181.302	91.190.218.59	10.0.0.45	TCP	54	
191	212.260	111.221.77.144	10.0.0.45	TCP	54	
193	212.569	111.221.77.144	10.0.0.45	TCP	54	
194	213.262	91.190.218.59	10.0.0.45	TCP	54	
196	213.398	91.190.218.59	10.0.0.45	TCP	54	

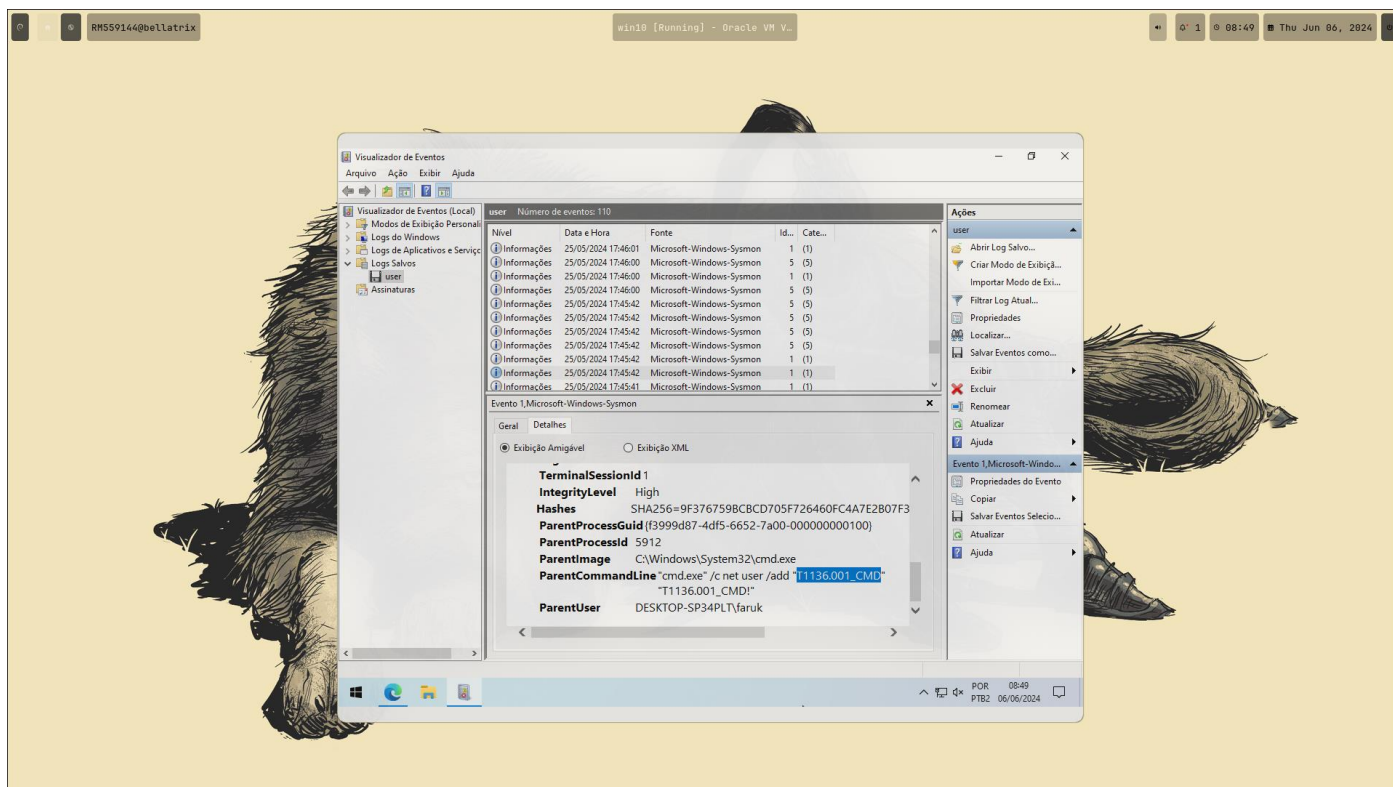
(Resolução do CTF TOP IP)

FIGURA 7 – TRAFFIC



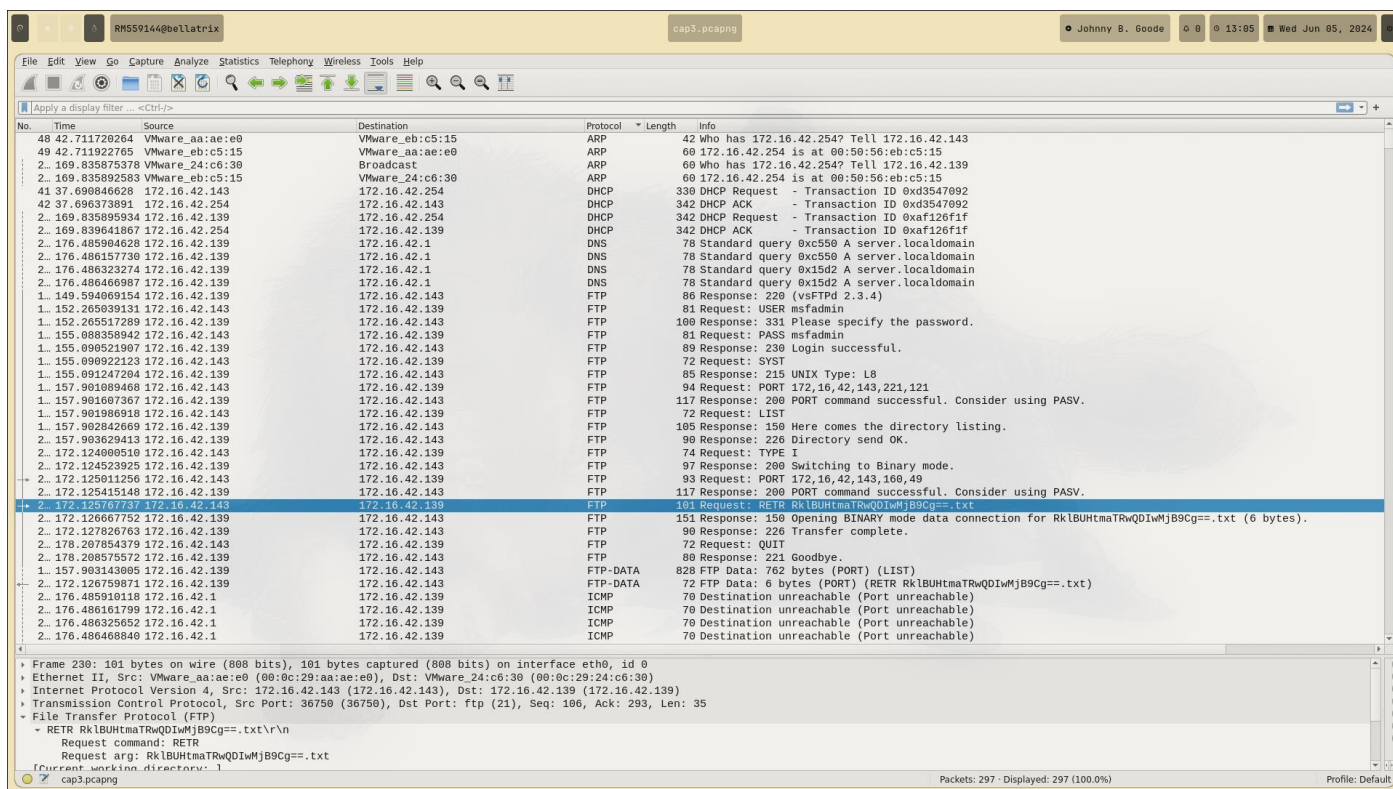
(Resolução do CTF SEXTO HOST)

FIGURA 8 – CAPTURED



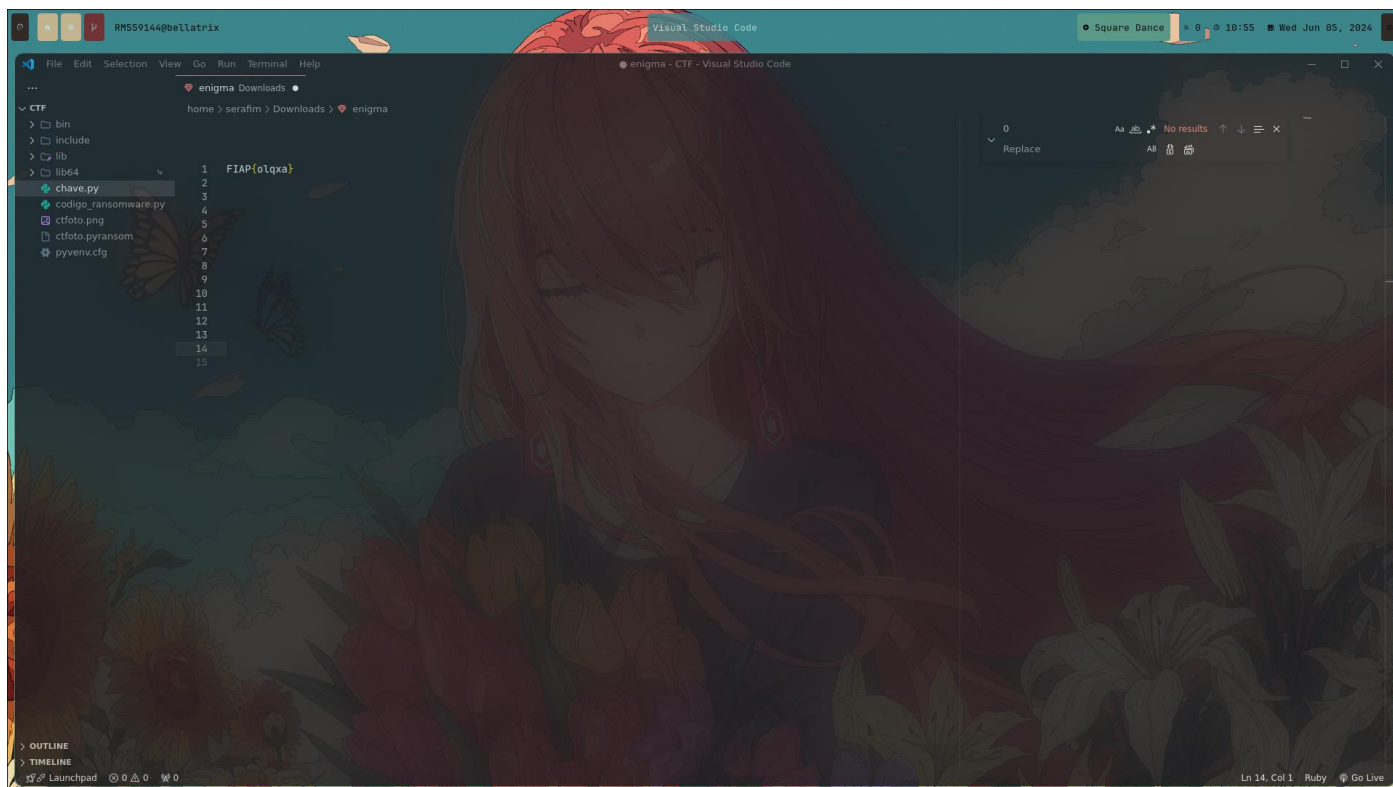
(Resolução do CTF USUÁRIO DESTRUIDOR)

FIGURA 9 – HALK



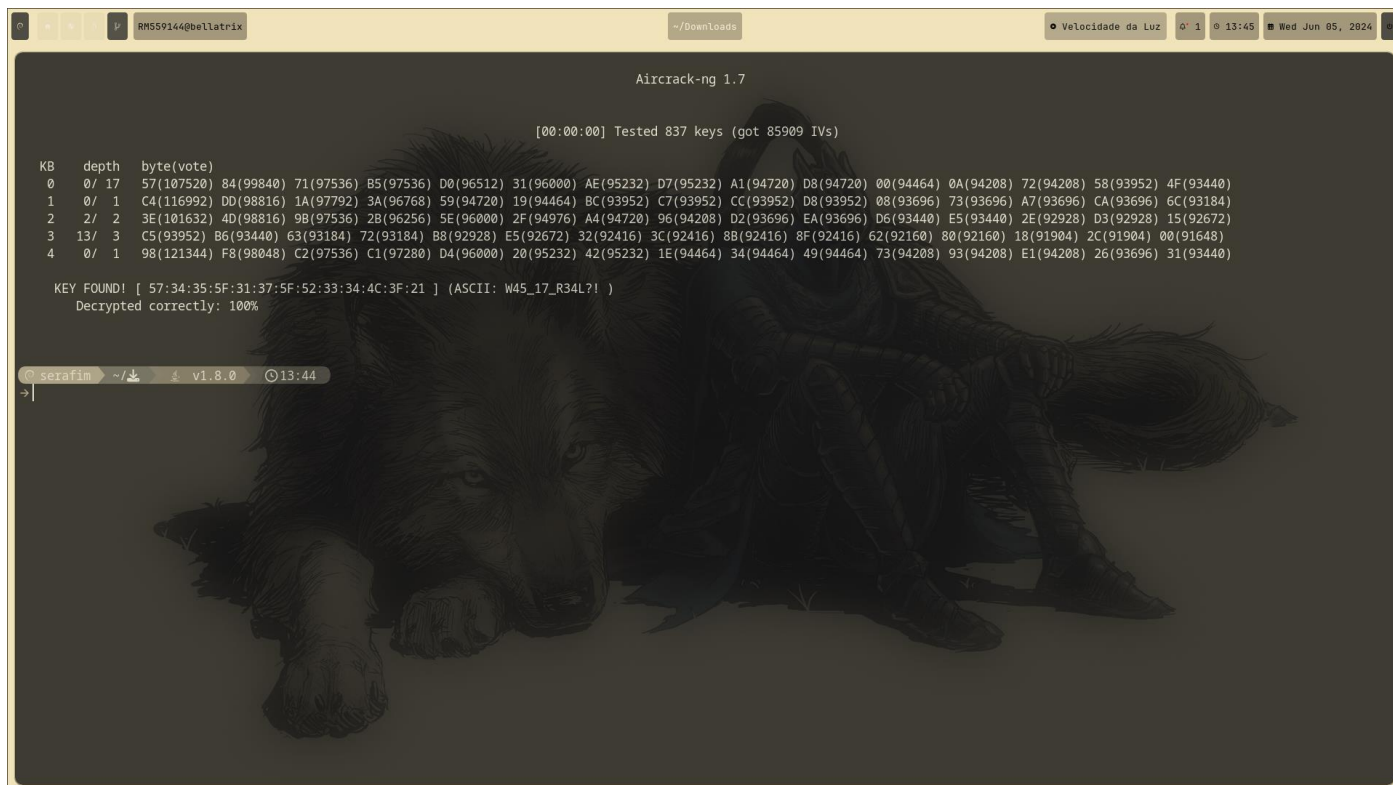
(Resolução do CTF VAZAMENTO)

FIGURA 10 – ALIEN



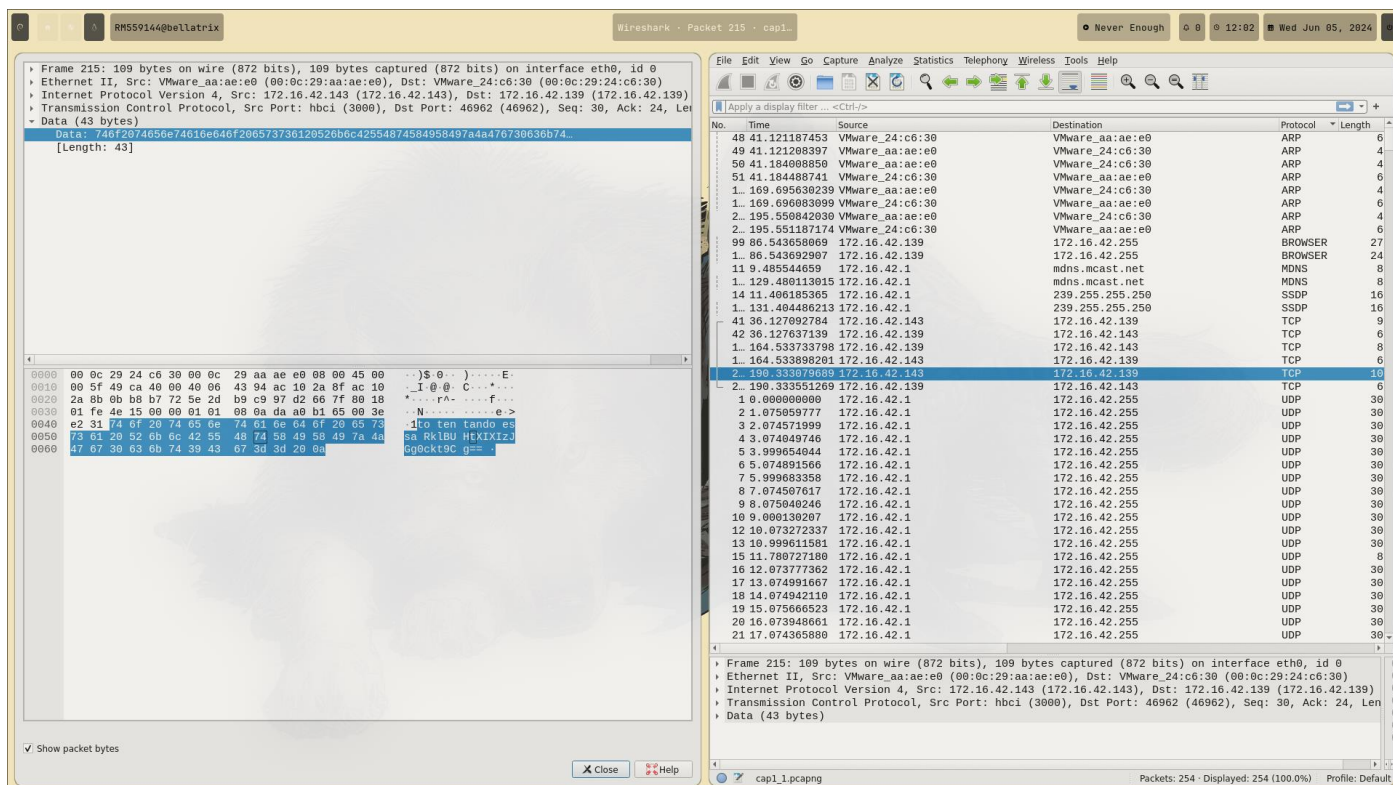
(Resolução do CTF CRIPTOGRAFIA ALIENÍGENA)

FIGURA 11 – WIFI



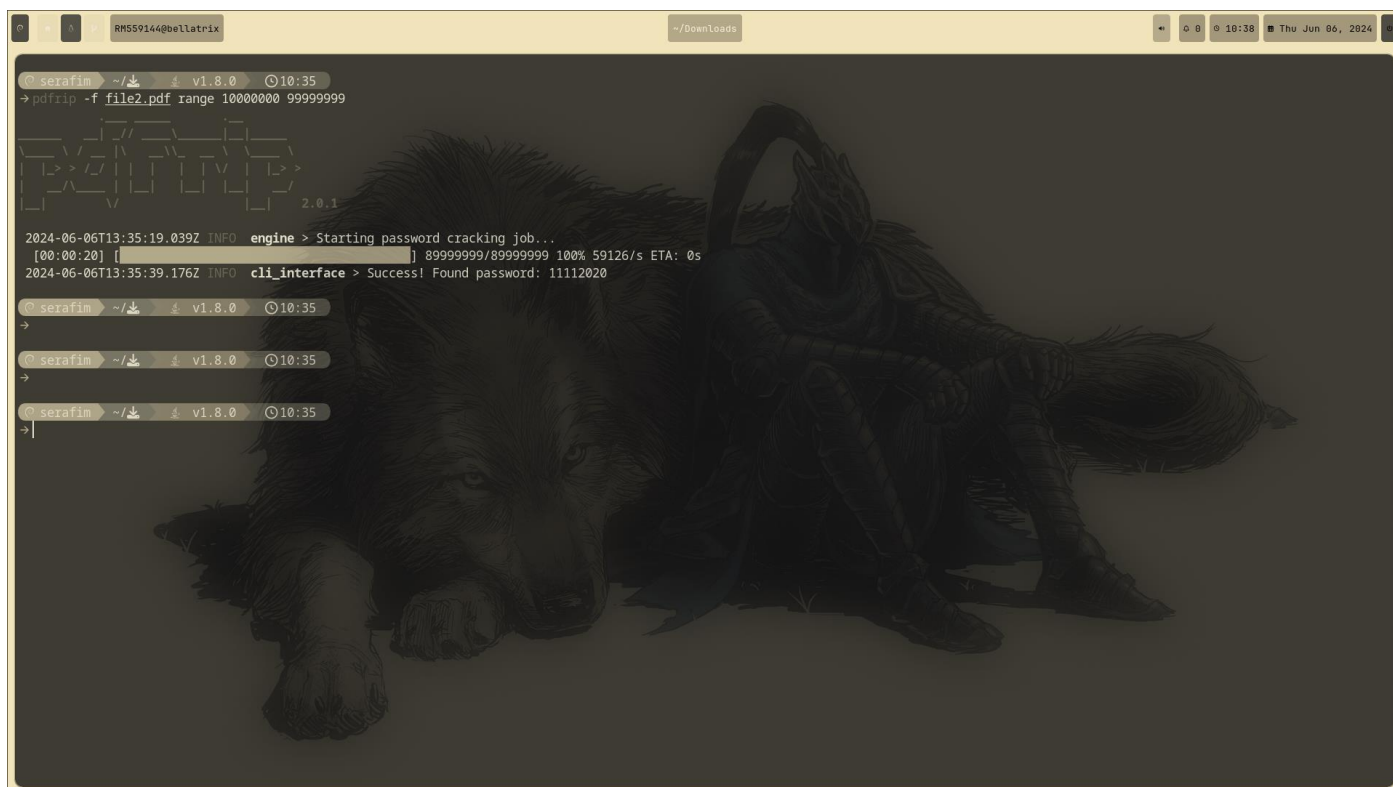
(Resolução do CTF OBSOLETO)

FIGURA 12 – CHAT



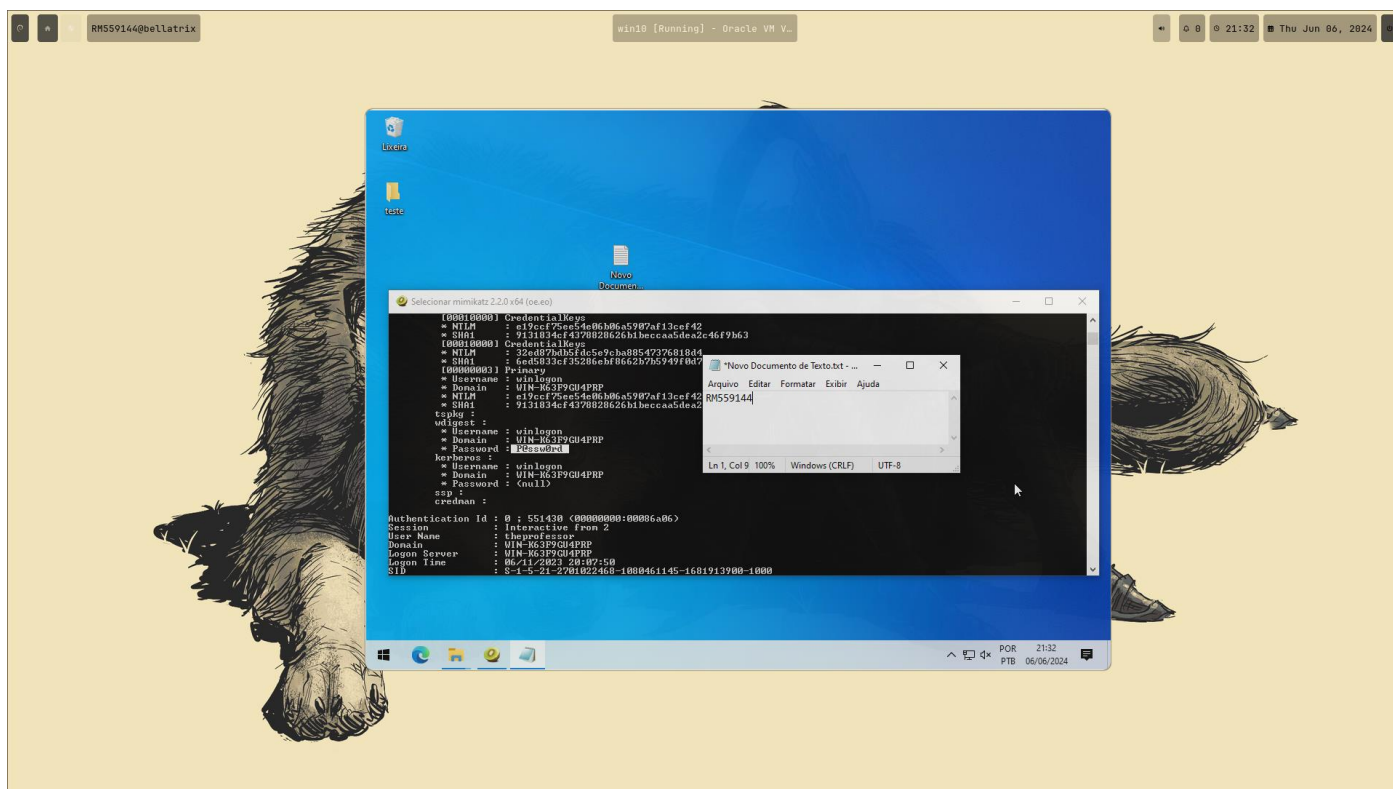
(Resolução do CTF CONVERSA SUSPEITA)

FIGURA 13 – RIPPER



(Resolução do CTF SOMENTE NUMEROS)

FIGURA 14 – *EXTRACTED*



(Resolução do CTF *BLUE OF DEATH*)

FIGURA 15 – DECRYPT

```

16 def decrypt_stage_two(message, now):
17     random.seed(now)
18     key = [random.randrange(256) for _ in message]
19
20     return [m ^ k for (m, k) in zip(message, key + [0x42] * len(now))][:-18]
21
22
23 def main() -> None:
24     with open("flag.enc", "rb") as f:
25         flag_enc = f.read()
26         now = bytes([0x42 * x for x in flag_enc[-18:]])
27         flag_dec = bytes(decrypt_stage_two(flag_enc, now))
28         print(flag_dec)
29
30     keys = list(permutations(range(8)))
31     flag_init = [BitVec(f"flag_{i}", 8) for i in range(len(flag_dec))]
32     for k in tqdm(keys[0:1000]):
33         s = Solver()
34         flag = flag_init.copy()
35         for i, c in enumerate(flag_dec):
36             s.add(flag[i] == c)
37             s.add(flag[i-1] == ord(" "))
38             for _ in range(42):
39                 flag = encrypt_stage_one(flag, k)
40             for i, c in enumerate(flag_dec):
41                 s.add(flag[i] == c)
42             if s.check() == sat:
43                 print("Found:")
44                 print(bytes([s.model()[x].as_long() for x in flag_init]))
45
46 if __name__ == '__main__':
47     main()

```

Terminal Output:

```

(CTF)
$ python3 decomp.py
b'0x42'
Found:
b'0x42'
(CTF)
$ python3 decomp.py
b'0x42'

```

(Resolução do CTF TEMPO E ESPAÇO)

FIGURA 16 – PING OF DEATH

```

1. from scapy.all import *
2. from yenc import decode
3.
4. pcap = rdpcap('f101.pcap')
5. f = open('f101.yenc', 'w')
6.
7. for p in pcap:
8.     if p[ICMP].type == 8:
9.         f.write(''.join(str(p[Raw])))
10.
11. f.close()
12.
13. decode('f101.yenc', 'f101.bin')

```

This gave us a binary file with an interesting content inside:

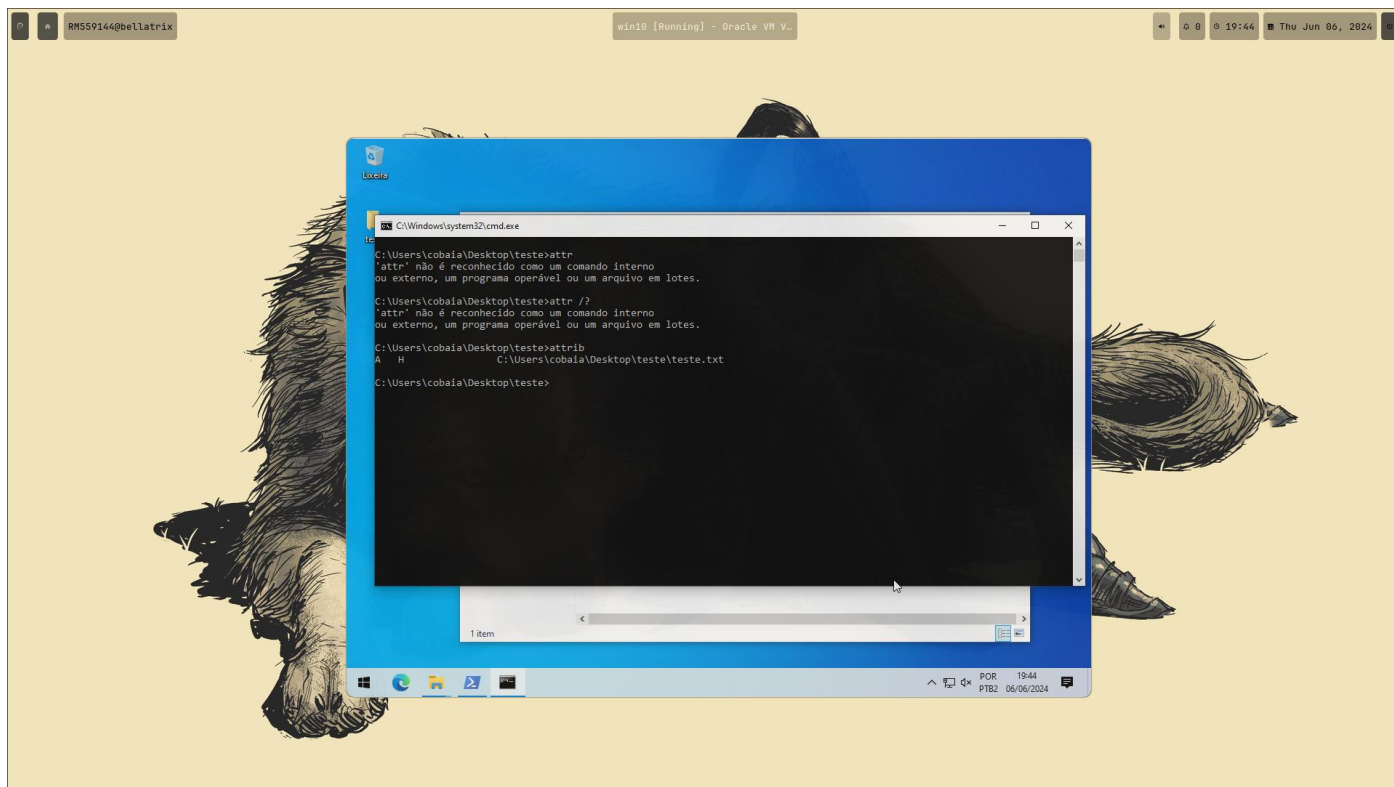
```

1. 00000000 0a3f 7b29 2b7b 7d5b 5d2b 3d3c 2b2f 285d 402b 5b5d 293f 265d 282e 3c7d 7b2a 255e
2. 00000001 3f7e 283f 7b26 2d3d 2e2e 405d 2d28 3d2d 5e2d 292d 2b7d 2a7d 3c7e 5d5e 3c28 5b5b
3. 00000002 2d0a 293a 7b2d 407d 2a5d 7c2a 2f7b 5b5b 7b7e 5b2f 2c28 7d7d 2b2f 407c 7b3f 3e2f
4. 00000003 3e25 267b 5b2b 3c2a 2c3d 285b 2d5e 407b 2c2f 283d 5d3c 2f3a 265e 2c3a 2629 3d2d
5. 00000004 2926 0a5a 574e 6f62 7941 695a 6949 4b5a 574e 6f62 7941 6962 4349 4b5a 574e 6f62
6. 00000005 7941 6959 5349 4b5a 574e 6f62 7941 695a 7949 4b5a 574e 6f62 7941 6965 7949 4b5a
7. 00000006 574e 6f0a 6279 4169 6257 5131 6333 5074 4967 706c 5932 6876 4943 406f 4a32 5a73
8. 00000007 5957 636e 4b53 494b 5a57 4e6f 6279 4169 6653 494b 3a7b 2b5d 3d5e 7e7e 2e40 2d5e
9. 00000008 3c2b 2e3e 0a3c 2f28 253e 2b28 292f 2a2e 7d28 3e25 3c2e 7b2a 253a 3e40 2c2d 7b2b
10. 00000009 2c5e 3f2c 2f40 2f7d 3a2b 293d 3d2e 257b 2d7e 253d 3e29 3a7d 2b5d 2a29 5d3d 7c40
11. 0000000a 2a3a 263e 3c8a 3f7b 2c5d 2e2d 2e7d 5e29 7e2e 3d7e 255d 7e3d 3c3d 3f2f 2f7b 4028
12.
13.

```

If we remove the newline from the ASCII text we get: ZWlObYA1ZIKZWNobyA1bC1KZWNobyA1YS1KZWNobyA1Zy1KZWNobyA1evIKZWNobyA1bW01C3VlTnY2bWl0Y2V0TnY2Zy1KZWNobyA1f101.yenc which is base64 for:

(Resolução do CTF CABO PERDIDO)

FIGURA 17 – *HIDDEN*

(Resolução do CTF COMANDO BÁSICO)

4. CONSIDERAÇÕES FINAIS

Este relatório técnico apresenta a resolução de *Capture the Flag* (CTFs) de defesa cibernética como ferramenta para aprimorar o aprendizado em técnicas de segurança da informação. Através da resolução de diferentes CTFs, o *Global Solution* explorou conceitos relevantes de segurança, abordando técnicas de ataque, defesa e análise forense.

A pesquisa se baseou na resolução de desafios em diferentes aspectos, com foco em desafios que abordassem temas como criptografia, análise de rede, engenharia reversa e exploração de vulnerabilidades. O processo de resolução envolveu a aplicação de ferramentas e técnicas de segurança da informação.

A resolução de CTFs se configura como uma ferramenta valiosa para o aprendizado em cursos de defesa cibernética. Através da prática *hands-on* (mão na massa), podemos consolidar os conhecimentos teóricos, desenvolver habilidades práticas e se preparam para os desafios do mercado de trabalho.

5.REFERÊNCIAS

HACKERSPACE, XIL. HackIM 2016 Misc 2 Writeup | Blog. Disponível em:
<<https://blog.xil.se/posts/hackim-2016-misc-2-arturo182/>>. Acesso em: 7 jun. 2024.

LI, A. SekaiCTF 2022 Writeups. Disponível em:
<<https://lebr0nli.github.io/blog/security/SekaiCTF-2022/>>. Acesso em: 8 jun. 2024.